PurpLedger

The Smart Ledger for Modern Collections

PRD ADDENDUM — v1.1

Merchant Verification & Tiered Access
Team RBAC & SuperAdmin Strategy

Extends PRD v1.0 · June 2025

CONFIDENTIAL — INTERNAL USE ONLY

PM REVIEW & EDITORIAL NOTES

Changes made before finalisation — read before implementing

The following corrections and additions have been applied to the source material before incorporation into this addendum. Developers and designers should treat the content in Sections 12–15 as the authoritative, corrected specification.

CORRECTION 1 — Limit Nomenclature Fix (Schema)

Source issue: The schema extension used daily_collection_limit, but the business logic throughout Section 12 consistently describes a monthly limit. These two are contradictory and would create a critical billing discrepancy.

Fix applied: Column renamed to monthly_collection_limit across schema and all API references in this document.

CORRECTION 2 — Tier 1 Monthly Limit (Business Decision)

Source issue: The ₦250,000 monthly cap for Tier 1 (Individual) merchants is too restrictive for freelancers doing even moderate B2B work. A single small contract invoice could exhaust the limit. This risks frustrating exactly the users we want to convert to Tier 2.

Fix applied: Tier 1 monthly limit raised to ₦500,000. This cap must be stored as a configurable admin-settable parameter (not hardcoded) so the SuperAdmin can adjust it without a code deployment.

CORRECTION 3 — Stripe Reference Removed (Stack Alignment)

Source issue: Section 15 (SuperAdmin Strategy) referenced 'Stripe or Paystack API Status' for system health monitoring. PurpLedger's stack is Paystack-only. Referencing Stripe introduces ambiguity and could misdirect developers.

Fix applied: All references changed to 'Paystack API Status (status.paystack.com)' exclusively.

CORRECTION 4 — Invoice Deletion Wording (Ledger Integrity)

Source issue: Section 15 stated: 'If a merchant deletes a ₦10M invoice, you see who did it.' This contradicts the core PRD v1.0 ledger-integrity principle — invoices are NEVER deleted. They can only be VOIDED (with a mandatory reason), which is a non-destructive status change.

Fix applied: Wording corrected to 'If a merchant voids a high-value invoice.' All audit log descriptions updated accordingly. No DELETE operation exists on the invoices table — only status transitions.

CORRECTION 5 — RBAC Schema UUID Consistency

Source issue: The roles table used SERIAL PRIMARY KEY (integer). Every other table in the schema (PRD v1.0 Section 5) uses UUID as primary keys. Mixing integer and UUID primary keys creates join inconsistencies and confuses ORM tooling.

Fix applied: roles.id changed to UUID DEFAULT gen_random_uuid(). merchant_team.role_id changed to UUID REFERENCES roles(id) accordingly.

ADDITION 1 — Suspended-Merchant Mid-Transaction State (Missing)

Gap identified: The source material defined link deactivation on SUSPENDED status but did not specify what happens to Paystack transactions that are in-flight at the moment of suspension (e.g., customer is on the Paystack checkout page when admin suspends the merchant).

Decision added: In-flight Paystack transactions (status: 'pending') are allowed to complete. On the webhook callback, the system checks merchant verification_status before updating invoice records. If SUSPENDED, the transaction is logged as success but funds are held pending admin review (implemented via Paystack's hold mechanism or manual subaccount freeze). See Section 12.6.

ADDITION 2 — Tier-Up Cooldown Window (Anti-Gaming)

Gap identified: The automated Tier-Up rule (₦1,000,000 collected without disputes) had no minimum time window. A merchant could theoretically invoice a friendly connection for ₦1M, collect immediately, and auto-upgrade in day one — bypassing the intent of the review.

Rule added: Automated Tier-Up invitation requires: (a) ₦1,000,000+ successfully collected AND (b) account age ≥ 60 days AND (c) zero chargebacks in the past 90 days. All three conditions must be true simultaneously. See Section 13.3.

ADDITION 3 — Invite Flow: Existing vs. New User (Missing)

Gap identified: The RBAC 'Add Member' flow described generating an invite link but did not differentiate between inviting someone who already has a PurpLedger account and someone brand new. These require different backend flows.

Spec added: Two-path invite resolution defined in Section 14.2.3: Existing Account Path (email matched in auth.users — link auto-associates on click, no new signup) and New Account Path (email not found — link redirects to streamlined signup that pre-populates merchant_team record on account creation).

ADDITION 4 — Manual Close Permission (RBAC Gap)

Gap identified: The Accountant role as defined can create and manage invoices, but neither the source material nor PRD v1.0 explicitly stated whether Accountants can execute Manual Invoice Closure — a high-stakes, irreversible action with audit implications.

Decision added: Manual Invoice Closure and Invoice Void are OWNER-ONLY actions. Accountants can create, edit (pre-payment), and view invoices, but the 'Close Manually' and 'Void' buttons are hidden and the API endpoint returns 403 for non-Owner roles. This is reflected in the RBAC permissions matrix in Section 14.1.

12. MERCHANT VERIFICATION & COMPLIANCE

Staged Access — Tiered Verification Model

12.1 Overview

To balance aggressive user acquisition with financial and legal safety, PurpLedger implements a Tiered Verification Model. This architecture allows unregistered businesses — freelancers, sole traders, small vendors — to immediately benefit from the Smart Ledger bookkeeping tools, while strictly gating the Paystack payment collection features behind identity verification.

The model follows a "Land and Expand" growth strategy: acquire users with zero friction, convert them to live payment collection once trust is established.

12.2 Merchant Tiers & Permissions

Feature	Tier 0: Starter	Tier 1: Individual	Tier 2: Corporate	Notes
Requirements	Email + Business Name	NIN or BVN + Phone	CAC Docs + Business Bank Acc	
Draft Invoicing	✓ Enabled	✓ Enabled	✓ Enabled	All tiers can create invoices
Payment Links	✗ Locked	✓ Enabled	✓ Enabled	Requires verification
QR Code Sharing	✗ Locked	✓ Enabled	✓ Enabled	Requires verification
PurpBot AI	✓ Enabled	✓ Enabled	✓ Enabled	Read-only on all tiers
Monthly Limit	₦0 (Bookkeeping)	₦500,000	Unlimited	Admin-configurable parameter
KYC Complexity	None	Low (Auto-validation)	High (Manual / API Review)	
Approval Time	Instant	Near-instant (API)	Up to 24 hours (human review)	

Important: Monthly Limit is Admin-Configurable

The ₦500,000 Tier 1 monthly collection limit must NOT be hardcoded. It must be stored in a platform_settings table as a configurable key-value pair. The SuperAdmin can adjust limits for all tiers without a code deployment. This allows the business to respond to market conditions and regulatory changes dynamically.

12.3 Verification State Machine

Status	Definition & Permitted Actions
UNVERIFIED (Default)	Merchant signed up but has not submitted identity documents. Can create, save, and internally view draft invoices. 'Share Link' and 'Download QR' buttons are disabled. Dashboard shows persistent upgrade banner.
PENDING	Merchant has submitted documentation (BVN/NIN or CAC). All payment distribution features remain locked. Merchant sees a 'Verification in Progress' status badge.
VERIFIED	Identity confirmed. Paystack Subaccount is activated. Payment links, QR codes, and real payment collection are fully functional. Monthly limit applies based on tier.
REJECTED	Documentation failed automated or human review. Admin has provided a reason code stored in kyc_notes. Merchant notified via email. Can re-submit after correction.
SUSPENDED	Platform-initiated. All existing public payment links immediately return 403 Forbidden. In-flight Paystack transactions (webhook pending) are allowed to complete but funds are held pending admin review. Merchant cannot create new payment links.

In-Flight Transaction Policy on Suspension

When a merchant transitions to SUSPENDED status, any Paystack transaction where the customer has already been redirected to the checkout page is considered 'in-flight.' These transactions are permitted to complete via the Paystack webhook. However, on webhook receipt, the system will log the transaction but flag the associated invoice record with a holds_pending_review flag. The SuperAdmin is notified and must manually release or refund the held amount. This prevents both customer fraud (payment disappears) and merchant fraud (collecting while under investigation).

12.4 Compliance-First UI Logic

12.4.1 Dashboard Upgrade Banner

For any merchant with verification_status = 'unverified' or 'pending', a persistent non-dismissible banner is rendered at the top of the dashboard:

Banner Content (Tier 0 — Unverified)

Background: purp-100 (#EDE9FE) | Border-left: 4px solid amethyst (#7B2FBE)

"You are in Bookkeeping Mode. Your invoices are saved but payment links are disabled. Verify your identity to start accepting live payments via Paystack."

CTA Button: 'Verify My Identity →' (purp-900 background, white text, flat — no gradient)

12.4.2 The 'Unlock Payment' Modal

When an unverified merchant clicks 'Share Invoice' or 'Download QR,' a Shadcn/UI Dialog modal appears instead of executing the action:

- Modal Header: "Ready to get paid?"
- Body: Brief explanation that identity verification is required to activate Paystack collections.
- Option A — Individual: 'I am a Freelancer / Individual' → Submits NIN or BVN via a secure form. Near-instant API validation via SmileID or Verified.africa.
- Option B — Corporate: 'I am a Registered Business (CAC)' → Uploads CAC Certificate and Business Bank Account details. Subject to 24-hour human review by Admin.
- Footer note: 'Your existing draft invoices are safe and will be activated the moment verification is complete.'

External Dependency: SmileID / Verified.africa

The automated BVN/NIN validation in the Individual path requires a paid API contract with either SmileID or Verified.africa (both support Nigerian identity validation). This is a Sprint 1 vendor dependency. The vendor contract and API keys must be provisioned before Sprint 3 (Payment Portal) goes live. If no contract is in place by Sprint 3, the Individual path must fall back to a manual review queue identical to the Corporate path.

12.4.3 PurpBot Verification-Aware Responses

PurpBot's system prompt must include a conditional instruction that checks the merchant's verification_status before responding to questions about distributing invoices or collecting payments:

PurpBot System Prompt Instruction (Pseudocode)

```
IF merchant.verification_status != 'verified':
  AND query_intent involves ['payment link', 'collect', 'cash flow',
'inflow', 'share invoice']:
  APPEND to response:
  "I can see you have [X] in outstanding invoices. To convert these into
  actual cash inflows, please complete your Identity Verification in
  Settings > Verification. It takes under 2 minutes for individuals."
```

12.5 Schema Extension (Addendum to PRD v1.0 Section 5.1)

The following columns are added to the existing merchants table defined in PRD v1.0 Section 5.1:

```
-- Schema Extension: Merchant Verification & Tiered Access
-- Addendum to PRD v1.0, Section 5.1 (merchants table)

ALTER TABLE merchants
```

```
  ADD COLUMN merchant_tier TEXT NOT NULL DEFAULT 'starter',
  --  Enum: 'starter' | 'individual' | 'corporate'

  ADD COLUMN kyc_submitted_at TIMESTAMPTZ,
  --  Timestamp of most recent KYC document submission

  ADD COLUMN kyc_notes TEXT,
  --  Admin-written reason for REJECTED status. Sent to merchant on
rejection.

  ADD COLUMN monthly_collection_limit NUMERIC(12,2) NOT NULL DEFAULT 0,
  --  CORRECTION: was 'daily_collection_limit' in source — FIXED to
monthly.
  --  ₦0 for Tier 0, ₦500,000 for Tier 1, NULL (no limit) for Tier 2.
  --  Value sourced from platform_settings, not hardcoded.

  ADD COLUMN holds_pending_review BOOLEAN NOT NULL DEFAULT false;
  --  ADDITION: Set to TRUE when merchant is SUSPENDED with in-flight txns.

-- Companion: Platform Settings table for admin-configurable limits
CREATE TABLE platform_settings (
  key TEXT PRIMARY KEY,  -- e.g., 'tier1_monthly_limit'
  value TEXT NOT NULL,
  updated_by UUID REFERENCES auth.users(id),
  updated_at TIMESTAMPTZ DEFAULT now()
);

-- Seed data
INSERT INTO platform_settings (key, value)
VALUES ('tier1_monthly_limit', '500000'),
       ('tier2_monthly_limit', 'unlimited'),
       ('auto_tier_up_threshold', '1000000'),
       ('auto_tier_up_min_account_age_days', '60'),
       ('auto_tier_up_chargeback_window_days', '90');
```

12.6 Risk Mitigation (API-Level Enforcement)

Risk	API Enforcement Rule
Unverified merchant collecting payments	GET /api/invoices/:id/public returns 403 Forbidden if merchant.verification_status != 'verified'. Error body: { code: 'MERCHANT_UNVERIFIED', message: 'This invoice is not currently accepting payments.' }
Tier 1 merchant exceeding monthly limit	POST /api/invoices/:id/pay checks sum of successful transactions for current calendar month against monthly_collection_limit. If limit would be exceeded, returns 402 with { code: 'LIMIT_EXCEEDED', message: 'Monthly collection limit reached. Upgrade to Corporate.' }
Suspended merchant with active links	ALL public invoice endpoints check verification_status on every request. Suspension takes effect within one request cycle — no caching of verification status on public routes.

Risk	API Enforcement Rule
In-flight payment at time of suspension	Webhook handler checks holds_pending_review flag. If true, transaction is logged with status = 'held_pending_review'. Invoice status does NOT update to 'paid/partially_paid' until admin manually releases.

13. SUPER ADMIN VERIFICATION PROTOCOL

KYC Review Queue & Automated Tier Management

13.1 Verification Inbox (Admin Queue)

The SuperAdmin dashboard features a dedicated 'Verification Inbox' as the primary KYC workflow surface. All PENDING and FLAGGED merchant applications are centralised here.

View Component	Specification
Pending Table	All merchants with verification_status = 'pending', sorted by kyc_submitted_at ascending (oldest first). Columns: Business Name, Tier Requested, Submission Age, Automated Check Status.
Automated Check Badge	Each row displays a colour-coded badge for the automated sanity check result: PASSED (green), FAILED (red), INCONCLUSIVE (amber). Admin must review FAILED and INCONCLUSIVE manually.
Document Viewer Panel	Secure side-panel that renders document previews (CAC certificate, identity proof) inline — no file downloads to local storage. Documents served via signed Supabase Storage URLs with 15-minute expiry.
Action Suite	Three primary CTA buttons per merchant: Approve, Reject (requires reason code selection + optional notes), and Request More Info (sends email to merchant with admin's question).
Flagged Tab	Separate tab for merchants flagged by the automated system or manually flagged by another admin. Includes flag reason and timestamp.

13.2 The Decision Logic (Step-by-Step)

Step 1: Automated Sanity Check (Pre-Human)

Before the application enters the human review queue, the system runs the following automated checks:

1. Duplicate Check: Query the database to determine if the submitted BVN, NIN, or CAC registration number already exists under another verified merchant account. If a match is found, auto-flag and escalate to human review with reason: 'Duplicate Identity Credential.'
2. API Identity Validation (Tier 1 Individual): Call SmileID or Verified.africa API to verify that the submitted BVN/NIN is active and that the name on file matches the merchant's business_name or registered owner name. Result stored as automated_check_status.
3. CAC Portal Cross-Reference (Tier 2 Corporate): Submit CAC number to the CAC API (or manual lookup if API unavailable) to confirm registration is active and not struck-off.
4. Result Routing: PASSED → Fast-track to auto-approval queue (Tier 1 only). FAILED → Block approval, notify merchant with specific failure reason. INCONCLUSIVE → Route to human review queue.

Vendor Dependency: SmileID / Verified.africa (Sprint 1 Blocker)

Steps 2 and 3 of the automated check require active API contracts with an identity verification vendor. This is a hard dependency. Without it, ALL individual verifications must be routed to human review, which does not scale. The vendor contract must be signed and API credentials provisioned before Sprint 3 delivery. Assign a contract owner immediately.

Step 2: Human Review (The Cubric Assessment)

For Tier 2 (Corporate) accounts and any Tier 1 with an INCONCLUSIVE automated result, the Admin follows this structured checklist. Each step is a clickable checkbox in the Admin UI — the Approve button is disabled until all checklist items are ticked:

5. Name Matching: Does the Business Bank Account Name match the CAC registration name or the identity document name?
6. Activity Audit: Review the merchant's audit_logs for suspicious draft invoice activity during the UNVERIFIED period (e.g., creating 20+ high-value invoices within 24 hours of signup — a potential advance-fee fraud pattern).
7. Blacklist Scan: Cross-reference the merchant's email address and phone number against the platform's internal fraudulent actor registry.
8. Document Authenticity: Inspect the uploaded document for signs of tampering (blurring, inconsistent fonts, pixelation around key fields).

Step 3: Action Execution

Action	System Behaviour
APPROVE	Updates verification_status = 'verified'. Sets merchant_tier to requested tier. Updates monthly_collection_limit from platform_settings. Activates Paystack Subaccount. Sends approval email to merchant. Logs event to audit_logs with verification_method = 'automated' or 'manual_review'.
REJECT	Admin selects mandatory Reason Code: 'Document Expired', 'Name Mismatch', 'Duplicate Identity', 'CAC Struck-Off', 'Suspicious Activity', 'Incomplete Submission', 'Other (freetext)'. Reason stored in kyc_notes. Rejection email sent to merchant. Merchant can resubmit after correcting the issue.
REQUEST MORE INFO	Admin types a specific question (minimum 10 characters). Email sent to merchant. Merchant status remains PENDING. Application remains in queue with 'Awaiting Merchant Response' badge. Auto-escalates to human review if no response in 5 business days.

13.3 Automated Tier-Up Logic

For Tier 1 (Individual) merchants, the platform runs a nightly background job to identify candidates for a Corporate Upgrade invitation. The Tier-Up invitation requires ALL three conditions to be simultaneously true:

- Condition A — Collection Threshold: Total successful collections since account creation >= ₦1,000,000
- Condition B — Account Maturity: Account age >= 60 days from creation date (prevents single-invoice gaming)
- Condition C — Clean History: Zero Paystack chargebacks recorded in the past 90 days

When all three conditions are met, the system:

9. Creates a notification in the merchant's dashboard: 'You qualify for Corporate status. This removes your monthly collection limit. Upload your CAC documents to upgrade.'
10. Flags the merchant in the Admin Verification Inbox with event type: 'tier_up_candidate'.
11. Does NOT automatically change the merchant's tier — upgrade still requires the merchant to submit CAC documents and Admin approval.

13.4 Admin Audit Log Format

Every verification action is logged to the audit_logs table (PRD v1.0 Section 5.6) with the following metadata structure:

```
-- Verification Approval Log
{
  "event": "merchant_verified",
  "admin_id": "uuid-of-admin",
  "merchant_id": "uuid-of-merchant",
  "old_status": "pending",
  "new_status": "verified",
  "old_tier": "starter",
  "new_tier": "individual",
  "verification_method": "manual_review",  // or "automated"
  "automated_check_result": "inconclusive",
  "checklist_completed": true,
  "monthly_limit_set": 500000,
  "notes": "Verified against CAC portal reference #998877"
}

-- Rejection Log
{
  "event": "merchant_rejected",
  "admin_id": "uuid-of-admin",
  "merchant_id": "uuid-of-merchant",
  "reason_code": "name_mismatch",
  "reason_detail": "Bank account name: Chidi Okafor. CAC name: Chidimma
Okafor Ltd. Names do not match.",
  "merchant_notified": true
}
```

14. TEAM ROLE-BASED ACCESS CONTROL (RBAC)

Merchant Portal Team Management

14.1 Role Definitions & Permissions Matrix

Within each merchant portal, the Owner can invite team members and assign them predefined or custom roles. The following matrix defines the permissions for each pre-defined role:

Permission / Action	Owner	Accountant	Viewer	Notes
Create Invoice	✓	✓	✗	
Edit Invoice (pre-payment)	✓	✓	✗	Edits locked once any payment received
Void Invoice	✓	✗	✗	Owner-only. Requires mandatory reason.
Manual Invoice Close	✓	✗	✗	Owner-only. High-stakes, audit-logged.
View All Invoices	✓	✓	✓	
View Financial Analytics	✓	✓	✓	Aging Report, Collection vs. Inflow
Use PurpBot AI	✓	✓	✓	Read-only for all roles by definition
Manage Clients (CRUD)	✓	✓	✗	Viewer sees client list, cannot edit
View Transactions	✓	✓	✓	
Manage Team Members	✓	✗	✗	Owner-only
Change Fee Absorption Setting	✓	✗	✗	Owner-only
Manage KYC / Verification	✓	✗	✗	Owner-only
Delete Team Member	✓	✗	✗	Owner-only. Soft-deactivate via is_active.

Custom Role Configuration

When an Owner selects the 'Custom' role type, the UI presents four toggle switches corresponding to permissions bundles: (1) Manage Invoices, (2) View Financial Reports, (3) Use PurpBot, (4) Manage Team Members. The resulting permissions JSONB is stored in the roles table. Custom roles cannot be assigned Manual Close or Void permissions regardless of toggle configuration — these remain Owner-only at the API middleware level.

14.2 Team Management Workflow

14.2.1 Invite Flow

12. Owner navigates to Settings > Team and clicks 'Invite Member.'
13. Owner enters the invitee's email address and selects a role from the dropdown: Owner, Accountant, Viewer, or Custom.
14. If Custom is selected, the four permission toggles are displayed.
15. Owner clicks 'Send Invite.' System generates a unique invite token (UUID-based, 48-hour expiry) and sends an invite email.
16. The invite is logged in a pending_invites table with status = 'pending'.

14.2.2 Invite Acceptance — Two-Path Resolution

When the invitee clicks the link in their invite email, the system checks whether the email address exists in auth.users:

Path	Flow
Existing PurpLedger Account	User is directed to the login page with a notification: 'You have been invited to join [Business Name] as [Role]. Log in to accept.' On successful login, merchant_team record is created and invite status = 'accepted'. User immediately sees the merchant portal in their account switcher.
New User (No Existing Account)	User is directed to a streamlined signup page pre-filled with their email address. On account creation, merchant_team record is automatically created with the pre-configured role. No additional invite acceptance step required. Invite status = 'accepted'.
Expired Invite (48h elapsed)	Link returns a friendly error page: 'This invite has expired. Ask your team owner to send a new invite.' Expired invites are auto-cleaned from pending_invites after 7 days.

14.2.3 Team Member Management

- Owner can view all team members, their roles, and their last-active timestamps.
- Owner can change a team member's role at any time. Change takes effect on their next API request.
- Owner can deactivate a team member (sets is_active = false on merchant_team). Deactivated members cannot log in to the portal. Their past actions remain in audit_logs.
- An Owner cannot deactivate themselves. At least one Owner must always be active on a merchant account.

14.3 Database Schema (New Tables)

```
-- Roles Table
-- CORRECTION: UUID primary key for schema consistency (was SERIAL in
source)
```

```
CREATE TABLE roles (
  id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
  name TEXT UNIQUE NOT NULL,  -- 'owner', 'accountant', 'viewer', 'custom'
  permissions JSONB NOT NULL, -- e.g., {"can_edit_invoice": true,
"can_void_invoice": false}
  is_system_role BOOLEAN NOT NULL DEFAULT false,  -- true for predefined
roles
  created_at TIMESTAMPTZ DEFAULT now()
);

-- Merchant Team Members
CREATE TABLE merchant_team (
  id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
  merchant_id UUID NOT NULL REFERENCES merchants(id) ON DELETE CASCADE,
  user_id UUID NOT NULL REFERENCES auth.users(id) ON DELETE CASCADE,
  role_id UUID NOT NULL REFERENCES roles(id),
  is_active BOOLEAN NOT NULL DEFAULT true,
  invited_by UUID REFERENCES auth.users(id),  -- the Owner who sent the
invite
  added_at TIMESTAMPTZ NOT NULL DEFAULT now(),
  last_active_at TIMESTAMPTZ,
  UNIQUE (merchant_id, user_id)  -- One role per user per merchant
);

-- Pending Invites
CREATE TABLE pending_invites (
  id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
  merchant_id UUID NOT NULL REFERENCES merchants(id) ON DELETE CASCADE,
  invited_email TEXT NOT NULL,
  role_id UUID NOT NULL REFERENCES roles(id),
  token TEXT NOT NULL UNIQUE,  -- Cryptographically random, used in invite
URL
  status TEXT NOT NULL DEFAULT 'pending',  -- 'pending', 'accepted',
'expired'
  expires_at TIMESTAMPTZ NOT NULL,  -- now() + INTERVAL '48 hours'
  created_by UUID NOT NULL REFERENCES auth.users(id),
  created_at TIMESTAMPTZ NOT NULL DEFAULT now()
);
```

14.4 Implementation Strategy

14.4.1 Frontend (useAuth Hook)

- A global useAuth hook reads the current user's role from merchant_team on session load.
- The hook exposes a can(permission: string): boolean helper used across all components.
- Usage example: {can('edit_invoice') && <Button>Edit</Button>} — gates UI elements declaratively.
- The 'Void' and 'Close Manually' buttons check can('manual_close') — which returns false for all non-Owner roles.

14.4.2 API Middleware (Server-Side Enforcement)

- Every API route that mutates data runs a checkPermission(userId, merchantId, requiredPermission) middleware function.
- The middleware queries merchant_team to get the user's role_id, then queries roles.permissions JSONB for the required permission key.
- If the permission is not granted, the endpoint returns 403 Forbidden with a descriptive error body.
- Frontend UI gates are cosmetic conveniences. Server-side middleware is the authoritative enforcement layer.

15. SUPERADMIN MONITORING STRATEGY

The Watchtower — Platform-Wide Oversight

15.1 Overview

The SuperAdmin portal (accessible at a separate, protected route) serves as the Watchtower of the entire PurpLedger ecosystem. The SuperAdmin does not create operational data; they monitor the health, legality, and financial integrity of the platform. All actions taken by the SuperAdmin are audit-logged.

15.2 Key Monitoring Modules

Module	Specification
Global Ledger	A real-time, paginated, searchable feed of all invoice events across the platform. Columns: Merchant Name, Invoice Number, Event Type, Amount, Timestamp. Filterable by date range, merchant, and event type. Read-only display — SuperAdmin cannot edit records.
KYC Verification Pipeline	The Verification Inbox described in Section 13. Primary operational surface for approving, rejecting, and monitoring merchant onboarding.
Audit Trail Master	A searchable, immutable log of ALL actions across the platform: invoice voids (CORRECTION: not deletions — invoices cannot be deleted), manual closures, team role changes, and verification decisions. If a merchant voids a high-value invoice, the log shows which merchant did it, at what timestamp, and with what stated reason.
Paystack System Health	Integration widget displaying the live status of Paystack's API and payment infrastructure via the official status page (status.paystack.com). CORRECTION: Stripe removed — PurpLedger is Paystack-only. Shows: API status, payment gateway status, and webhook delivery status.
Merchant Risk Scoring	Automated risk signals surfaced in the admin UI: high-value invoice creation by unverified accounts, unusual manual close rates, rapid client creation, repeated failed payment attempts on a single invoice.
Platform GMV Dashboard	Real-time total transaction volume across all merchants. Segmented by day/week/month. Separate views for Gross Volume (total initiated) and Net Volume (successfully collected).

15.3 Access Security

- SuperAdmin portal is isolated at the route level: /admin/** routes require is_super_admin = true in Supabase Auth user metadata.

- SuperAdmin login requires separate credentials from regular merchant accounts — no shared session.
- All SuperAdmin sessions require 2FA (TOTP authenticator app mandatory, SMS as fallback only).
- SuperAdmin actions are logged with both the admin_id and the IP address of the session for forensic traceability.
- SuperAdmin cannot log in from the regular merchant portal UI. They are completely separate applications (separate Next.js route groups or separate deployments).

15.4 Sprint Assignment

Component	Target Sprint
Section 12: Tiered Verification — Schema & State Machine	Sprint 1
Section 12: Compliance-First UI (Banner, Modal, Soft-blocks)	Sprint 2
Section 13: Automated Sanity Check (SmileID Integration)	Sprint 3 (vendor-dependent)
Section 13: Admin Verification Inbox & Manual Review UI	Sprint 4
Section 13: Tier-Up Automation Background Job	Sprint 5
Section 14: RBAC Schema & Middleware	Sprint 1.5 (between S1 and S2)
Section 14: Team Invite UI & Two-Path Resolution	Sprint 2
Section 15: SuperAdmin Monitoring Dashboard	Sprint 6
Section 15: Global Ledger & Audit Trail Master	Sprint 6
Section 15: Paystack System Health Widget	Sprint 6

— END OF ADDENDUM v1.1 —

This document extends PRD v1.0. Both documents must be read together as the complete specification.

PurpLedger PRD Addendum v1.1 · Confidential · © 2025 PurpLedger